

Checklist Esencial de Seguridad de Red

Guía práctica con los controles de seguridad imprescindibles para proteger la infraestructura de red de su empresa

Edición 2026

¿Tiene dudas? Hable directamente con el CEO

David Pérez

WhatsApp: 655 100 400

Índice de Contenidos

Introducción — La seguridad de red como prioridad empresarial	3
Capítulo 1 — Gestión de Acceso y Contraseñas	5
Capítulo 2 — Seguridad del Perímetro de Red	7
Capítulo 3 — Protección de Endpoints y Servidores	9
Capítulo 4 — Gestión de Vulnerabilidades	11
Capítulo 5 — Copias de Seguridad y Recuperación	13
Capítulo 6 — Monitorización y Respuesta a Incidentes	15
Capítulo 7 — Formación y Concienciación	17
Checklist resumen ejecutivo	19

Introducción

El 60% de las PYMEs que sufren un ciberataque grave cierran en los 6 meses siguientes. La seguridad de red ya no es opcional: es una cuestión de supervivencia empresarial.

Los ciberataques a empresas españolas han aumentado un 35% en el último año, con un coste medio por incidente de 105.000 € para las PYMEs. El ransomware, el phishing y las intrusiones en la red son las amenazas más frecuentes, y ninguna empresa está exenta de riesgo.

Este checklist le proporciona una guía práctica y accionable para evaluar y mejorar la seguridad de su infraestructura de red. Cada sección incluye controles específicos que puede implementar de forma progresiva.

Alerta: Si su empresa maneja datos personales (clientes, empleados, pacientes), el RGPD le obliga a implementar medidas técnicas y organizativas adecuadas. El incumplimiento puede suponer multas de hasta el 4% de la facturación anual.

Capítulo 1 — Gestión de Acceso y Contraseñas

El control de acceso es la primera línea de defensa. El 81% de las brechas de seguridad están relacionadas con contraseñas débiles o robadas.

- ☐ Política de contraseñas robustas (mínimo 12 caracteres, combinando mayúsculas, minúsculas, números y símbolos)
- ☐ Autenticación multifactor (MFA) activada en todos los accesos críticos
- ☐ Cambio obligatorio de contraseñas cada 90 días
- ☐ Bloqueo automático de cuentas tras 5 intentos fallidos
- ☐ Eliminación inmediata de accesos de empleados que causan baja
- ☐ Principio de mínimo privilegio: cada usuario solo accede a lo que necesita
- ☐ Registro y auditoría de todos los accesos a sistemas críticos
- ☐ Uso de gestor de contraseñas corporativo (LastPass, 1Password, Bitwarden)
- ☐ Prohibición de compartir credenciales entre empleados
- ☐ Revisión trimestral de permisos y accesos

Recomendación: Implemente un sistema de Single Sign-On (SSO) para centralizar la autenticación y reducir el número de contraseñas que sus empleados deben gestionar.

Capítulo 2 — Seguridad del Perímetro de Red

El perímetro de red es la frontera entre su red interna y el mundo exterior. Un perímetro mal configurado es una puerta abierta para los atacantes.

- ☐ Firewall de nueva generación (NGFW) instalado y configurado
- ☐ Reglas de firewall revisadas y actualizadas (eliminar reglas obsoletas)
- ☐ Sistema de detección/prevencción de intrusiones (IDS/IPS) activo
- ☐ Segmentación de red: separar redes de producción, invitados y IoT
- ☐ VPN corporativa para acceso remoto de empleados
- ☐ Filtrado de contenido web para bloquear sitios maliciosos
- ☐ Protección anti-DDoS configurada
- ☐ DMZ configurada para servicios expuestos a internet
- ☐ Puertos no utilizados cerrados en el firewall
- ☐ Logs del firewall monitorizados y almacenados (mínimo 12 meses)

Tipo de firewall	Protección	Ideal para
Firewall básico (stateful)	Filtrado de paquetes por IP/puerto	Microempresas (1-5 empleados)
UTM (Unified Threat Management)	Firewall + antivirus + IPS + VPN	PYMEs (5-50 empleados)
NGFW (Next-Generation Firewall)	UTM + inspección SSL + control de aplicaciones	Empresas medianas (50-500)
Firewall cloud / SASE	Seguridad perimetral cloud + SD-WAN	Empresas distribuidas multi-sede

Capítulo 3 — Protección de Endpoints y Servidores

Cada dispositivo conectado a su red es un potencial punto de entrada para los atacantes.

- ☐ Antivirus/EDR empresarial instalado en todos los equipos
- ☐ Sistema operativo actualizado con los últimos parches de seguridad
- ☐ Cifrado de disco completo en portátiles y dispositivos móviles
- ☐ Control de dispositivos USB (bloqueo o restricción)
- ☐ Política de BYOD (Bring Your Own Device) definida y aplicada
- ☐ Gestión centralizada de dispositivos móviles (MDM)
- ☐ Servidores con hardening aplicado (servicios innecesarios desactivados)
- ☐ Acceso a servidores solo mediante VPN o red interna
- ☐ Monitorización de procesos y conexiones sospechosas
- ☐ Inventario actualizado de todos los dispositivos de la red

Internet Operadores recomienda: Implemente una solución EDR (Endpoint Detection and Response) en lugar de un antivirus tradicional. Las soluciones EDR detectan amenazas avanzadas que los antivirus convencionales no pueden identificar.

Capítulo 4 — Gestión de Vulnerabilidades

Las vulnerabilidades no parcheadas son la causa del 60% de las brechas de seguridad. Un programa de gestión de vulnerabilidades es esencial.

- ☐ Escaneo de vulnerabilidades trimestral (mínimo)
- ☐ Parches de seguridad críticos aplicados en menos de 48 horas
- ☐ Actualizaciones de firmware de routers, switches y APs al día
- ☐ Software no soportado identificado y planificada su sustitución
- ☐ Test de penetración anual realizado por empresa externa
- ☐ Proceso documentado de gestión de parches
- ☐ Inventario de software con versiones actualizadas

Priorización de vulnerabilidades

Severidad CVSS	Nivel	Plazo de parcheo	Ejemplo
9.0 - 10.0	Crítica	24-48 horas	Ejecución remota de código sin autenticación
7.0 - 8.9	Alta	1 semana	Escalada de privilegios local
4.0 - 6.9	Media	1 mes	Divulgación de información
0.1 - 3.9	Baja	Próximo ciclo de mantenimiento	Denegación de servicio local

Capítulo 5 — Copias de Seguridad y Recuperación

La regla 3-2-1: 3 copias de sus datos, en 2 soportes diferentes, con 1 copia fuera de sus instalaciones.

- ☐ Política de backup documentada y aplicada
- ☐ Backups automáticos diarios de datos críticos
- ☐ Al menos una copia offsite o en la nube
- ☐ Backups cifrados en tránsito y en reposo
- ☐ Pruebas de restauración mensuales documentadas
- ☐ RPO (Recovery Point Objective) definido para cada sistema
- ☐ RTO (Recovery Time Objective) definido y probado
- ☐ Plan de recuperación ante desastres (DRP) documentado
- ☐ Backups protegidos contra ransomware (inmutables)
- ☐ Retención de backups según requisitos legales (mínimo 5 años para datos fiscales)

Solución ExaGrid: Internet Operadores ofrece ExaGrid como solución de backup empresarial con deduplicación, retención a largo plazo y protección anti-ransomware integrada. Consulte nuestra guía específica de ExaGrid para más información.

Capítulo 6 — Monitorización y Respuesta a Incidentes

Detectar una amenaza a tiempo puede marcar la diferencia entre un incidente menor y una catástrofe empresarial.

- ☐ Sistema de monitorización de red activo 24/7
- ☐ Alertas configuradas para eventos de seguridad críticos
- ☐ Logs centralizados en un SIEM o sistema equivalente
- ☐ Plan de respuesta a incidentes documentado
- ☐ Equipo de respuesta a incidentes identificado con roles claros
- ☐ Procedimiento de notificación a la AEPD en caso de brecha de datos (72 horas)
- ☐ Contacto de empresa de respuesta a incidentes externa
- ☐ Simulacros de incidentes realizados al menos una vez al año

Capítulo 7 — Formación y Concienciación

El eslabón más débil de la cadena de seguridad es el factor humano. El 95% de los incidentes de seguridad involucran un error humano.

- ☐ Formación en ciberseguridad para todos los empleados (al menos anual)
- ☐ Simulacros de phishing periódicos
- ☐ Política de uso aceptable de recursos IT firmada por todos los empleados
- ☐ Protocolo claro para reportar emails o actividad sospechosa
- ☐ Formación específica para personal con acceso privilegiado
- ☐ Material de concienciación visible (pósters, emails periódicos)

Checklist Resumen Ejecutivo

Área	Controles clave	Estado
Acceso y contraseñas	MFA activado, política de contraseñas, mínimo privilegio	☐
Perímetro de red	NGFW configurado, VPN, segmentación, IDS/IPS	☐
Endpoints	EDR instalado, cifrado de disco, MDM, inventario	☐
Vulnerabilidades	Escaneo trimestral, parches < 48h, pentest anual	☐
Backup	Regla 3-2-1, pruebas mensuales, DRP documentado	☐
Monitorización	SIEM, alertas 24/7, plan de respuesta a incidentes	☐
Formación	Formación anual, simulacros phishing, política de uso	☐

¿Necesita ayuda? Internet Operadores ofrece auditorías de seguridad gratuitas para evaluar el estado de su infraestructura y proponer un plan de mejora adaptado a su presupuesto.

¿Necesita ayuda con su proyecto?

Nuestro equipo de expertos está a su disposición para asesorarle sin compromiso.

Llame al 900 XXX XXX · WhatsApp: 655 100 400 ·
comercial@internetoperadores.com

© 2026 Internet Operadores. Todos los derechos reservados.

Este documento es propiedad de Internet Operadores. Queda prohibida su reproducción sin autorización.